

وثيقة التصميم الفني وبنية البرمجيات الهندسية

منظومة استكشاف الشبكات، وتحليل الحزم، وإدارة الأصول الذكية (LumiNet Core)

دليل المطور الكامل لتصميم الباك اند وآليات الفحص الشبكي الآمن، وجدولة استكشاف الأصول، مع تحليل شامل لبنية الربط والتكامل مع منصات SOC و SOAR و GRC داخل النظام البيئي للمشروع.

اسم الأداة الفرعية: LumiNet Advanced Operations
طبيعة المستند: دليل تفصيلي لبناء الباك اند ومخطط التكامل المعماري
تاريخ الإصدار: مايو 2026
الحالة: جاهز للتنفيذ والربط البرمجي

1. تحليل الربط المعماري ومدى ضرورة التكامل الفني

قبل الدخول في التفاصيل البرمجية لـ الباك اند، يجب حسم مسألة ربط أداة الشبكات (LumiNet) بمنصة **Unified SOC & Detection Engineering Platform** الإجابة الفنية الفاطعة هي: نعم، الربط ليس مفيداً فحسب، بل هو حتمي وجوهري للغاية لإنشاء نظام دفاعي متكامل وعميق (Defense-in-Depth).

1.1 لماذا يعتبر الربط مع منصة الـ SOC وهندسة الكشف أمراً ضرورياً؟

- تخيل أن منصة هندسة الكشف تمتلك قاعدة اكتشاف (Sigma Rule) تبحث عن محاولات التحرك الجانبي (Lateral بدون الربط مع أداة الشبكة، سيعلم المحلل أن SMB، أو ثغرة في بروتوكول WinRM عبر بروتوكول (Movement) هناك هجوماً، لكنه لن يمتلك أي سياق حول الجهاز المستهدف. الربط يوفر الفوائد الاستراتيجية التالية:
- **السياق الفوري للأصول (Context-Aware Detection):** بمجرد إطلاق تنبيه من الـ Rule Builder، يتم سحب بيانات الجهاز فوراً من الـ Asset Inventory (نوع الجهاز، نظام التشغيل، المنافذ المفتوحة) لمساعدة المحلل في تقييم مدى خطورة الهجوم.
- **تغذية معمل الاختبار بسجلات حقيقية (PCAP & Live Traffic Injection):** أداة السخريه والـ Sniffing الشبكي يمكنها التقاط حزم حقيقية (بصيغة PCAP) وتمريبها إلى الـ Simulation & Testing Lab لتجربة القواعد على حركة مرور شبكية فعلية بدلاً من السجلات الوهمية.
- **تصفية متطورة للتنبيهات الكاذبة (Advanced FP Tuning):** إذا أطلقت قاعدة سيجما تنبيهاً حول اتصال مريب على منفذ معين، وكان نظام المسح الشبكي (Network Scan) يؤكد أن هذا المنفذ مغلق أصلاً على هذا الجهاز أو مخصص لخدمة شرعية مسجلة، يمكن لمحرك التصفية إخماد التنبيه تلقائياً.

1.2 مخطط تدفق البيانات بين الأنظمة الأربعة المترابطة

تعمل الأداة كعصب حسي يغذي الأنظمة الأخرى بالمعلومات اللحظية من قلب الشبكة وفقاً للنموذج التالي:

1. **إلى الـ SIEM:** إرسال سجلات الأحداث الشبكية، وتغيرات الأجهزة، واكتشاف المنافذ المفتوحة الجديدة كـ خام Logs.
2. **إلى الـ SOAR:** تزويد موديول الاستجابة بالقدرة على عزل الجهاز شبكياً، أو قطع اتصالات الـ Sniffing المريبة فوراً عبر سكريبتات الأتمتة (Playbooks).
3. **إلى الـ GRC:** تحديث سجل الأصول والمخاطر آلياً (Asset Inventory Sync) بمجرد رصد جهاز جديد، وإرسال تقارير سوء التكوين (Misconfigurations) لحساب مؤشر الامتثال ومستوى المخاطر.
4. **إلى الـ SOC Platform:** تقديم الدعم المعرفي والسياسي للـ Alerts وإتاحة اختبار القواعد الشبكية داخل المعمل المعزول.

2. المواصفات الوظيفية والموديولات الأساسية للأداة

تم تصميم الأداة لتكون شاملة، تجمع بين مهام الرصد السلبي (Passive Monitoring) والفحص النشط (Active OSI لضمان التغطية الكاملة للطبقة الثانية والثالثة والرابعة من نموذج Scanning).

2.1 الموديولات التشغيلية الستة

- **استكشاف الشبكة (Network Discovery):** فحص النطاقات الشبكية (Subnets) باستخدام حزم ICMP ورسم خريطة (Host Alive Detection) لمعرفة الأجهزة المتصلة حالياً ARP Requests و Echo Requests طوبولوجية حية.
- **الفحص الذكي للخدمات والمنافذ (Port & Services Scanning):** فحص منافذ TCP/UDP باستخدام تقنيات متنوعة (SYN Scan, Connect Scan) وتحديد إصدارات الخدمات المشغلة (Banner Grabbing).
- **التنصت وتحليل الحزم (Network Sniffing & PCAP Parsing):** التقاط حركة المرور عبر بطاقة الشبكة في الوضع المختلط (Promiscuous Mode) وفك تشفير البروتوكولات (HTTP, DNS, TLS, FTP) لاستخراج المؤشرات المربية.
- **جرد الأصول الآلي (Automated Asset Inventory):** بناء قاعدة بيانات مركزية لكل الأجهزة المكتشفة، تشمل الماك أدريس (MAC Address)، الآي بي الحاضر، نظام التشغيل المخمن، وآخر ظهور للجهاز على الشبكة.
- **رصد سوء التكوين (Misconfiguration Detection):** فحص بروتوكولات الشبكة لمقارنتها بأفضل الممارسات الأمنية (مثل اكتشاف تفعيل بروتوكولات قديمة وغير مشفرة ك Telnet أو SMBv1 أو أنظمة توجيه خاطئة).
- **تحليل التدفق والفيضان الشبكي (Network Flow & Overflow Monitoring):** مراقبة حجم البيانات المتبادلة لكل جهاز لحساب العتبة الطبيعية (Baseline)، ورصد أي ارتفاع مفاجئ يشير إلى هجوم حجب الخدمة (Data Exfiltration) أو تسريب بيانات (DoS).

3. البنية التقنية البرمجية للباك اند وروابط الـ APIs

يتم بناء الباك اند باستخدام لغة **Python** نظراً للدعم الهائل الذي توفره مكتبات التعامل مع الحزم المنخفضة المستوى مع استخدام إطار عمل سريع لتقديم الخدمات البرمجية. تعتمد العمليات الطويلة (مثل مسح (Low-level Packets) شبكة كاملة أو تشغيل التنصت لعدة ساعات) على محرك مهام خلفي (Background Worker) لضمان عدم تجميد واجهة المستخدم.

3.1 المكتبات والأدوات التقنية المعتمدة في الباك اند

- **Scapy / Libpcap:** لالتقاط الحزم، وصناعة حزم مخصصة، وتحليل بروتوكولات الطبقات المختلفة برمجياً.
- **Nmap Engine (Python-nmap wrapper):** لتنفيذ عمليات مسح المنافذ المتقدمة وتحديد نوع نظام التشغيل (OS Fingerprinting) بكفاءة عالية وبشكل موازٍ (Asynchronous).
- **Psutil / Socket Libraries:** لمراقبة استهلاك بطاقات الشبكة المحلية والتدفق الخاص بالسيرفر المستضيف.

3.2 تصميم ومواصفات روابط الواجهة البرمجية (RESTful API Specifications)

يجب على الباك اند تقديم الروابط التالية بدقة متناهية مع معالجة الأخطاء وإرجاع الحالات المناسبة:

3.2.1 موديول الاستكشاف والفحص والـ Asset Inventory

الرابط (Endpoint)	الطريقة (Method)	الوصف الفني التفصيلي للـ رابط	المدخلات والمخرجات (Payload / Response)
/api/v1/network/discover	POST	بدء عملية استكشاف الأجهزة النشطة داخل نطاق شبكي محدد عبر ARP/ICMP.	In: { "subnet": "192.168.1.0/24" } Out: { "task_id": "job_9923" }
/api/v1/network/scan-ports	POST	إطلاق فحص للمنافذ والخدمات لجهاز معين أو مجموعة أجهزة.	In: { "target": "192.168.1.50", "ports": "1-1024", "type": "SYN" }
/api/v1/assets/inventory	GET	جلب قائمة الأصول المسجلة والمحدثة بالكامل مع الفلترة حسب نوع نظام التشغيل.	os_type, statusQuery params:
/api/v1/assets/details/{mac}	GET	عرض السجل التاريخي الكامل للجهاز بما فيها الخدمات المكتشفة عليه وسوء التكوين.	الـ MAC Address كمعرف فريد لا يتغير بتغير الآي بي.

3.2.2 موديول التنصت، كشف سوء التكوين، والتدفق الشامل

الرابط (Endpoint)	الطريقة (Method)	الوصف الفني التفصيلي للـ رابط	المدخلات والمخرجات (Payload / Response)
/api/v1/sniffing/start	POST	تفعيل التقاط الحزم السلبي على كارت شبكة محدد مع تحديد فلاتر برمجية (BPF).	In: { "interface": "eth0", "duration_sec": 300, "filter": "port 80" }
/api/v1/sniffing/live-stream	GET	رابط تواصل مستمر لضخ الحزم (WebSocket) المكتشفة فوراً للواجهة الأمامية.	بث مباشر لبيانات الحزم المفككة (JSON Stream).
/api/v1/network/misconfigurations	GET	استعراض ثغرات سوء التكوين النشطة المكتشفة في الشبكة وتصنيف خطورتها.	قائمة تشمل البروتوكولات غير الآمنة المكتشفة وموقعها.
/api/v1/network/flow-metrics	GET	جلب البيانات اللحظية لحجم العبء الشبكية واكتشاف حالات الـ Overflow والفيضان.	معدلات الـ Packets Per Second والـ Bandwidth المستهلك.

3.3 التصميم البرمجي لمعالجة حزم الـ Sniffing وحساب الـ Baseline للتدفق

لمنع انهيار الباك اند عند التعامل مع آلاف الحزم في الثانية أثناء الـ Sniffing، يجب على المطور تطبيق معمارية **Producer-Consumer Pattern** لتقاط الحزم ووضعها في طابور سريع في الذاكرة (Thread-safe) بسحب الحزم وتفكيكها وحفظها، مما يضمن عدم (Worker Threads) بينما تقوم خيوط معالجة أخرى (Queue)، سقوط أي حزمة (No Packet Drop).

آلية حساب التدفق الطبيعي ورصد الفيضان (Overflow Detection Logic):

يقوم الباك اند بحساب المتوسط المتحرك (Moving Average) لحجم البيانات لكل أصل شبكي على مدار 24 ساعة. إذا تجاوز حجم التدفق الحالي للجهاز قيمة ($Average + (3 * Standard Deviation)$)، يتم تصنيف الحالة فوراً كـ **Network Overflow / Traffic Anomaly**. ويقوم الباك اند بإرسال تذكير فوري كحدث أمني حرج إلى أنظمة الـ SIEM والـ SOAR المربوطة لاتخاذ إجراءات الحظر والدفاع.

4. بروتوكولات التكامل والربط مع الأنظمة الخارجية

القدرة الحقيقية لهذه الأداة تكمن في سلاسة حديثها وتبادلها للمعلومات مع بقية موديولات مشروع التخرج الأمنية والإدارية عبر آليات برمجية متفق عليها ومقننة.

4.1 التكامل مع نظام الـ SOAR (Orchestration & Automated Response)

عند قيام أداة الشبكة برصد سلوك مريب (مثل جهاز يقوم بعمل مسح لـ 5000 منفذ خلال دقيقة واحدة "Aggressive Port Scan")، يقوم الباك اند بإرسال (**Webhook Notification**) فوري إلى سيرفر الـ SOAR يحتوي على المعرفات الرقمية للجهاز المهاجم. يقوم الـ SOAR فوراً بتشغيل Playbook آلي يقوم بالتواصل مع رابط العزل الخاص بأداة الشبكة أو جدار الحماية لقطع اتصاله كلياً.

4.2 التكامل مع نظام الـ GRC (Governance, Risk, and Compliance)

تعتمد أداة الـ GRC على سجل أصول دقيق لحساب المخاطر. بمجرد انتهاء موديول الـ Asset Inventory من رصد أي جهاز جديد أو رصد ثغرة سوء تكوين (Misconfiguration) مثل سيرفر متاح عليه بروتوكول Telnet القديم، يتم استدعاء الـ API الخاصة بالـ GRC لإنشاء تذكرة خطر (Risk Ticket) جديدة آلياً وربطها بنظام الامتثال ومعايير ISO 27001.

5. خطة العمل وتوزيع المهام البرمجية لمهندس الباك اند

تم صياغة المهام الهندسية بدقة لتغطية كافة جوانب الأداة البرمجية والتحقق من سلامة الأكواد ومقاومتها للثغرات قبل دمجها النهائي.

المرحلة الأولى: إعداد البيئة وموديول الاستكشاف والأصول (Sprint 1)

رمز المهمة	عنوان المهمة البرمجية للمطور	المدخلات والمخرجات التقنية المتوقعة (Deliverables)	الزمن المتوقع
NET-101	بناء محرك فحص الـ ICMP/ARP الخفي	كود بايثون متوازي قادر على إرسال حزم استكشافية لنطاق كامل وجمع الردود دون إبطاء السيرفر.	يومان
NET-102	تطوير قاعدة بيانات الأصول (Asset Schema)	بناء جداول الأصول وربط الـ MAC Addresses بالخدمات والتاريخ الزمني للتغيرات الشبكية للأجهزة.	يومان
NET-103	تطوير روابط الـ CRUD لإدارة وجرد الأصول	بناء الـ APIs الخاصة باستعراض الأصول وتصنيفها والبحث عنها وتحديث الحالات يدوياً أو آلياً.	يوم واحد

المرحلة الثانية: محرك الفحص المتقدم ومسح الخدمات (Sprint 2)

رمز المهمة	عنوان المهمة البرمجية للمطور	المدخلات والمخرجات التقنية المتوقعة (Deliverables)	الزمن المتوقع
NET-201	دمج وتغليف محرك Nmap برمجياً	تطوير Wrapper يتعامل مع مكتبة Nmap لتنفيذ فحص المنافذ واستخراج الـ Banners وتخمين نظام التشغيل.	3 أيام
NET-202	بناء نظام إدارة طوابير الفحص (Scan Queue Manager)	إعداد نظام لجدولة عمليات الفحص لضمان عدم إطلاق أكثر من فحص عدواني في نفس الوقت مما يضر بالشبكة.	يومان

المرحلة الثالثة: محرك التنصت وتحليل البروتوكولات (Sprint 3)

رمز المهمة	عنوان المهمة البرمجية للمطور	المدخلات والمخرجات التقنية المتوقعة (Deliverables)	الزمن المتوقع
NET-301	تطوير موديول التقاط الحزم بوضعية الـ Sniffing	كود بايثون يتكامل مع Libpcap لالتقاط حزم البيانات بشكل مستمر واستخراج حقول الطبقة الثالثة والرابعة.	3 أيام
NET-302	بناء موديول تفكيك الحزم (Protocol Parser Engine)	أداة برمجية تفكك محتويات حزم DNS و HTTP لاستخراج النطاقات المطلوبة والمؤشرات الأساسية كبيانات مهيكلة.	يومان
NET-303	تفعيل قنوات البث الفوري (WebSockets Integration)	إعداد سيرفر WebSocket داخل الباك اند لصخ تيار الحزم المكتشفة فوراً إلى لوحة التحكم الأمامية.	يومان

المرحلة الرابعة: موديول رصد التدفق وسوء التكوين (Sprint 4)

رمز المهمة	عنوان المهمة البرمجية للمطور	المدخلات والمخرجات التقنية المتوقعة (Deliverables)	الزمن المتوقع
NET-401	تطوير خوارزمية رصد الفيضان والـ Overflow	محرك رياضي مدمج لمراقبة الـ Baseline وحجم التدفق والتبليغ عن حالات الشذوذ وحجم الترافيك الضخم.	يومان
NET-402	بناء قواعد فحص سوء التكوين (Misconfiguration Rules)	سكريبتات برمجية تفحص حركة المرور ونتائج الفحص للتأكد من خلو الشبكة من بروتوكولات ضعيفة أو غير مشفرة.	يومان

المرحلة الخامسة: الربط التكاملي والتحسين النهائي والتكامل (Sprint 5)

رمز المهمة	عنوان المهمة البرمجية للمطور	المدخلات والمخرجات التقنية المتوقعة (Deliverables)	الزمن المتوقع
NET-501	بناء أنظمة التبليغ والويب هوك (SOAR / GRC / SIEM Connectors)	تطوير الـ Clients والـ Webhooks المسؤولة عن دفع البيانات والملفات المسجلة آلياً للأنظمة الثلاثة الأخرى فوراً.	3 أيام
NET-502	تحسين الباك اند ضد ثغرات الـ Command Injection	مراجعة كافة الأكواد التي تستدعي أدوات النظام الخارجية (Nmap/عزل كروت) وتأمين المدخلات لمنع اختراق السيرفر.	يومان
NET-503	الاختبارات الشاملة وضبط الأداء (Load & Integration Testing)	تأكيد تماسك النظام عند التقاط ترافيك شبكي كثيف والتحقق من سلاسة تدفق البيانات عبر الأنظمة الأربعة بنجاح.	يومان

ملاحظة أمنية هامة للمطور:

يتطلب تشغيل أدوات الـ Sniffing وفحص الـ SYN صلاحيات جذورية (Root/Administrator Privileges) على السيرفر المستضيف لفتح الـ Raw Sockets. يجب تصميم الخدمة لتعمل بأقل صلاحيات ممكنة بعد تشغيل المنفذ، أو عزل الجزء المسؤول عن التقاط الحزم في خدمة صغيرة منفصلة (Privilege Separation) لضمان أعلى مستويات الأمان البنيوي للمنصة.